Team StAABility

(Team 10)

AAB College

ICDC 2026

White Team Documentation

Document Date: February 16, 2026

Table of Contents

Public Services (Setup for Service Scanner) 3
Network Architecture Overview 4
Network Control and Segmentation Model 5
Server Hardening Overview 6
Domain Controller (ad.team10.isucdc.com) 8
Tickets Server (tickets.team10.isucdc.com) 10
Management Server (mgmt.team10.isucdc.com) 12
Admin UI Server (admin.team10.isucdc.com) 15
Public Web Server (www.team10.isucdc.com) 17
Monitoring / SOC Implementation 18
Certificate and Authentication Controls 21
Overall Defensive Strategy 23

Public Services (Setup for Service Scanner)

Service Availability Matrix

The following services have been configured for accessibility from the competition network and are monitored for uptime scoring:

Server	IP Address	Service	Port	Protocol
Domain Controller	6.87.159.10	LDAP	389	TCP
Domain Controller	6.87.159.10	LDAPS	636	TCP
Domain Controller	6.87.159.10	RDP	3389	TCP
Tickets Server	6.87.159.20	HTTP (Ticketing API)	5000	TCP
Tickets Server	6.87.159.20	RDP	3389	TCP
Management Server	6.87.159.30	HTTP (Backend API)	5000	TCP
Management Server	6.87.159.30	SSH	22	TCP
Admin UI Server	6.87.159.40	HTTP	80	TCP
Admin UI Server	6.87.159.40	RDP	3389	TCP
Public Web Server	6.87.159.50	HTTP	80	TCP
Public Web Server	6.87.159.50	SSH	22	TCP

DNS Configuration

DNS records have been configured via IScorE for the following hostnames:

1. ad.team10.isucdc.com > 6.87.159.10
2. tickets.team10.isucdc.com > 6.87.159.20
3. mgmt.team10.isucdc.com > 6.87.159.30
4. admin.team10.isucdc.com > 6.87.159.40
5. www.team10.isucdc.com > 6.87.159.50

Network Architecture Overview

Infrastructure Design

The Central Downtown City (CDC) transportation management infrastructure consists of five primary servers deployed in a flat network architecture within the 6.87.159.0/24 subnet. All systems are joined to the Active Directory domain (ad.team10.isucdc.com) for centralized authentication and certificate services.

Network Topology

The infrastructure follows a service-oriented architecture with the following logical separation:

- Authentication Layer: Domain Controller (6.87.159.10) provides LDAP/LDAPS authentication for all services and user accounts.
- Application Layer: Management backend (6.87.159.30) serves as the primary business logic tier, handling ticket validation, payment processing, and fleet management.
- Presentation Layer: Admin UI (6.87.159.40) and Public Web (6.87.159.50) provide user-facing interfaces for administrative and public access respectively.
- Ticketing Infrastructure: Dedicated ticketing server (6.87.159.20) handles cryptographic ticket signing and validation operations.
- Fleet Communication: An externally managed simulation host at X.X.X.60 simulates bus and train communications with the management backend.

Service Dependencies

Critical dependencies have been mapped to ensure proper service restoration priority:

- All services depend on Domain Controller for LDAP authentication.
- Admin UI and Public Web servers depend on Management Backend API availability.
- Management Backend depends on Tickets Server for ticket validation operations.
- Ticketing operations require certificate services from Domain Controller.
- Public ticket scanning functionality requires end-to-end connectivity across all layers.

Network Control and Segmentation Model

Network Control Limitations

The competition infrastructure operates within a centrally managed network environment. The primary gateway and upstream routing controls are administered externally by the competition organizers.

As a result:

- Custom firewall appliances (e.g., pfSense) cannot be inserted as default gateways.
- Network-level segmentation (VLAN isolation or routed subnets) cannot be implemented by the Blue Team.
- All servers reside within the allocated competition subnet (6.87.159.0/24).

Host-Based Segmentation Strategy

Due to the externally managed gateway architecture, network segmentation is enforced at the host level through the following mechanisms:

- Windows Firewall with restrictive inbound rules
- Linux firewalld/iptables default-deny ingress policies
- Service binding restrictions (localhost-bound database services)
- Principle of least privilege for inter-service communication

Inter-system communication is restricted strictly to explicitly required service ports. Unnecessary east-west traffic is mitigated through host-based firewall enforcement

Architectural Implications

This model ensures:

- Controlled service exposure aligned with competition scoring requirements
- Reduced lateral movement surface within the flat subnet architecture
- Defense-in-depth enforcement despite gateway management constraints

Server Hardening Overview

Baseline Security Posture

A comprehensive hardening strategy has been implemented across all infrastructure components. The approach prioritizes defense-in-depth through layered security controls, privilege minimization, and proactive monitoring.

Windows Server Hardening Standards

All Windows-based servers (Domain Controller, Tickets Server, Admin UI Server) have been hardened using a consistent baseline:

- SysHardener applied for system-level security configuration.
- OSArmor deployed for application whitelisting and behavioral protection.
- Windows Firewall Control configured with restrictive default policies.
- RDPGuard installed on externally-facing RDP services for brute-force mitigation.
- Exe Radar Pro deployed for executable monitoring and anomaly detection.
- Group Policy Objects (GPOs) configured for password policies, account lockout, and audit logging.
- Unnecessary services disabled to reduce attack surface.
- Local administrator accounts reviewed and non-essential accounts removed.

Linux Server Hardening Standards

Linux servers (Management Backend, Public Web) have been secured following industry best practices:

- Root SSH login disabled across all Linux systems.
- Firewall (firewalld/iptables) enabled with default-deny ingress policies.
- Auditd configured for file integrity monitoring and privileged command logging.
- Intrusion detection/prevention systems enabled for network-based threat detection.
- System logs centralized to /var/log/secure for authentication event analysis.
- File permissions reviewed and restricted according to principle of least privilege.
- Unnecessary packages and services removed to minimize exposure.

Application Security

Application-level security controls have been implemented across all web services:

- Default pages and debugging endpoints removed from production deployments.
- Flask SECRET_KEY values configured with cryptographically secure random values.
- Environment variables properly configured for production deployments.
- Service dependencies validated and hardcoded localhost references corrected.
- Application logs reviewed for information disclosure vulnerabilities.
- Error handling configured to prevent stack trace exposure to end users.

Domain Controller (ad.team10.isucdc.com)

System Information

Parameter	Value
Hostname	ad.team10.isucdc.com
IP Address	6.87.159.10
Operating System	Windows Server 2016
Role	Active Directory Domain Services, Certificate Authority
Domain	ad.team10.isucdc.com

Security Configuration

Active Directory Hardening

The domain controller has been secured through systematic user account review and privilege minimization. All unnecessary user accounts identified during infrastructure review have been disabled or removed. Group Policy Objects have been configured to enforce organization-wide security policies including password complexity requirements, account lockout thresholds, and audit logging for privileged access attempts.

Host-Based Security Controls

• RDPGuard: Installed and configured to prevent brute-force attacks against Remote Desktop Services. Automatic IP blocking enabled for repeated failed authentication attempts.

• OSArmor: Deployed for behavioral analysis and application control. Configured to prevent execution of unauthorized binaries and scripts.

• SysHardener: System hardening utility applied to disable unnecessary Windows features and services.

• Windows Firewall Control: Custom firewall rules implemented to restrict inbound connections to essential services only (LDAP, LDAPS, RDP).

• Exe Radar Pro: Executable monitoring solution deployed to track process creation and identify anomalous binary execution patterns.

Certificate Services

The domain controller operates as the enterprise Certificate Authority for the CDC infrastructure. Certificate services provide cryptographic infrastructure for the ticketing system's signing and validation operations. The CA has been configured to issue certificates to the ticketing server upon request via the certutil interface. Certificate enrollment permissions have been restricted to authorized service accounts only.

Service Exposure

The following services are exposed to the competition network:

- LDAP (TCP/389): Provides directory services for user authentication across all infrastructure components.
- LDAPS (TCP/636): Encrypted LDAP communication for secure authentication operations.
- RDP (TCP/3389): Remote Desktop access for IT Administrator personnel with domain admin privileges.
- Certificate Services: Available to ticketing server for certificate enrollment operations.

Privilege Model

IT Administrator accounts maintain full domain administrative privileges with unrestricted sudo/Administrator access. Service accounts have been configured with least-privilege permissions scoped to their specific operational requirements. Regular user accounts are prohibited from RDP access to the domain controller.

Tickets Server (tickets.team10.isucdc.com)

System Information

Parameter	Value
Hostname	tickets.team10.isucdc.com
IP Address	6.87.159.20
Operating System	Windows Server 2019
Role	Ticket Issuance and Validation Service
Application Location	C:\Users\Administrator\Desktop\tickets

Application Architecture

The ticketing application provides RESTful API endpoints for cryptographic ticket operations. The service issues digitally signed tickets containing expiration timestamps and validates tickets presented by users. Tickets are signed using certificates obtained from the domain controller's Certificate Authority. The application has been compiled and deployed according to scenario requirements to ensure proper operational functionality and scoring compliance.

Security Configuration

Cryptographic Controls

The SIGNING_CERT_THUMBPRINT environment variable has been configured to reference the appropriate certificate for ticket signing operations. Certificate thumbprint validation ensures that only authorized certificates issued by the enterprise CA are used for cryptographic operations. The application validates certificate chain integrity before performing signing operations.

Host Hardening

- SysHardener: Applied for baseline security configuration.
- OSArmor: Configured for application whitelisting and behavioral monitoring.
- Windows Firewall Control: Custom firewall rules restrict inbound connections to RDP (3389) and HTTP (5000).
- Manual Firewall Rules: Additional rules configured to prevent unauthorized network access.
- Service Persistence: Application configured to start automatically via Windows Task Scheduler.

Long-Expiration Ticket Handling

Expiration handling mechanisms have been preserved to guarantee application compatibility and uninterrupted service functionality.

Service Exposure

The following services are accessible from the competition network:

- HTTP (TCP/5000): Ticketing API for ticket issuance and validation operations.
- RDP (TCP/3389): Remote Desktop access for IT Administrators and Ticket Maintenance personnel.

Monitoring Configuration

Port-level monitoring has been established for both exposed services (TCP/3389 and TCP/5000). Windows Event Log monitoring focuses on authentication events, specifically Event IDs 4624 (successful logon) and 4625 (failed logon). Brute-force detection mechanisms analyze failed authentication patterns and trigger alerts when threshold conditions are met.

Management Server (mgmt.team10.isucdc.com)

System Information

Parameter	Value
Hostname	mgmt.team10.isucdc.com
IP Address	6.87.159.30
Operating System	AlmaLinux 8.4
Role	Transit Management Backend
Application Location	/home/cdc/icdc26-backend-mgmt

Application Architecture

The management backend serves as the primary business logic tier for the CDC transportation infrastructure. The application provides RESTful API services for user authentication, ticket payment processing, and fleet management operations. Service deployment is managed through the 'backend' systemd service, enabling automated startup and lifecycle management.

Fleet Communication

An externally managed simulation host at X.X.X.60 simulates bus and train communications with the management backend. This machine continuously transmits telemetry data including vehicle location, status, and operational metrics. The management backend processes these messages and updates the fleet status database accordingly. This machine is not accessible to the Blue Team and is not a target for Red Team operations.

Security Configuration

SSH Hardening

Root SSH login has been disabled system-wide through sshd_config modifications. This prevents direct remote access using the root account and forces privilege escalation through sudo after initial authentication. Key-based authentication has been evaluated for implementation where appropriate to reduce password-based attack surface.

Firewall Configuration

Firewalld has been enabled and configured with restrictive default policies. Inbound traffic is limited to SSH (TCP/22) and HTTP (TCP/5000) services. All other ports are blocked by default. Connection tracking is enabled to maintain stateful inspection of network flows.

Audit Logging

Auditd has been configured to provide comprehensive system integrity monitoring. Audit rules capture privileged command execution, file system modifications to sensitive directories, and security-relevant system calls. Logs are retained in /var/log/audit/ and are monitored for suspicious activity patterns.

Intrusion Detection

Network-based intrusion detection and prevention systems have been enabled to provide real-time threat detection. Traffic analysis focuses on identifying malicious patterns including reconnaissance scans, exploitation attempts, and command-and-control communications. Detection signatures are updated to address current threat intelligence.

Service Exposure

- HTTP (TCP/5000): Management backend API accessible to admin UI, public website, and fleet communication systems.
- SSH (TCP/22): Administrative access for IT Administrator personnel with sudo privileges.

Database Security

The application database contains payment records, user credentials, and fleet management data. Database access controls restrict connectivity to localhost only, preventing direct external database connections. Critical application records required for scenario functionality have been preserved and protected through strict database access controls and file permission restrictions.

Monitoring Configuration

Authentication event logging is centralized to /var/log/secure. Automated analysis detects brute-force patterns by identifying excessive failed authentication attempts from individual source IP addresses. Alert thresholds trigger notifications when suspicious activity is detected.

Admin UI Server (admin.team10.isucdc.com)

System Information

Parameter	Value
Hostname	admin.team10.isucdc.com
IP Address	6.87.159.40
Operating System	Windows Server 2022
Role	Administrative Web Interface
Application Location	C:\Users\Administrator\Desktop\icdc26-admin-ui

Application Configuration

The Admin UI includes functionality to disable buses or trains through a dedicated control interface located within the Vehicles management section. When invoked, the application communicates with the management backend API to update fleet operational status in accordance with authorized administrative actions. All interactions are secured through authenticated API requests and enforced by role-based access control mechanisms.

Deployment Corrections

Initial deployment issues have been addressed to restore full functionality. The default IIS landing page was removed to expose the Flask application. Flask deployment configuration was corrected to ensure proper WSGI initialization. A scheduled task has been configured to provide service persistence, automatically starting the application on system boot. These modifications stabilized the admin dashboard and restored access to all management features.

Security Configuration

Standard Windows Server hardening measures have been applied consistent with other infrastructure components. The application requires Transit Admin credentials for authentication, which are validated against the Active Directory domain controller via LDAP. Authorization controls restrict access to administrative functions based on group membership.

Service Exposure

- HTTP (TCP/80): Administrative web interface accessible to Transit Admin users from the competition network.
- RDP (TCP/3389): Remote Desktop access for IT Administrator personnel with administrative privileges.

Public Web Server (www.team10.isucdc.com)
System Information

Parameter	Value
Hostname	www.team10.isucdc.com
IP Address	6.87.159.50
Operating System	AlmaLinux 9
Role	Public-Facing Web Application
Application Location	/home/cdc/icdc2026frontend-main

Application Architecture

The public website serves as the citizen-facing interface for the CDC transportation system. Users can register accounts, view bus and train routes, manage account information, purchase tickets, and validate tickets by scanning QR codes. The application is implemented as a Flask-based web service managed through systemd for automated lifecycle management.

Service Restoration

Significant configuration corrections were required to restore full service functionality. HTTP service on port 80 was reestablished by enabling the httpd/Apache service. The frontend systemd service was stabilized through proper configuration of environment variables. The FLASK_APP configuration variable was corrected to point to the appropriate application entry point. Backend connectivity was restored by correcting the management server URL from localhost references to the proper IP address (6.87.159.30). The Flask SECRET_KEY was configured with a cryptographically secure value to enable session management.

Security Configuration

Linux server hardening measures have been applied consistent with the management backend server. SSH root login is disabled, firewall rules restrict inbound traffic to essential services, and system audit logging is enabled. User authentication is handled through integration with the management backend API, which validates credentials against Active Directory.

Service Exposure

HTTP (TCP/80): Public website accessible to all users from the competition network for registration, route viewing, ticket purchase, and ticket scanning

SSH (TCP/22): Administrative access for IT Administrator personnel with sudo privileges.

Monitoring / SOC Implementation

Monitoring Architecture

A comprehensive monitoring infrastructure has been established to provide visibility into authentication events, service availability, and potential security incidents. Monitoring capabilities span both Windows and Linux platforms with centralized log analysis and alerting mechanisms.

Windows Event Monitoring

Windows servers generate security events to the Windows Event Log subsystem. Primary focus areas include:

- Event ID 4624: Successful logon events tracked across all Windows systems to establish baseline access patterns.
- Event ID 4625: Failed logon events monitored for brute-force attack detection and threshold alerting.
- Service-specific events: Application logs reviewed for error conditions and service availability issues.
- RDPGuard integration: Automated IP blocking triggered by repeated failed authentication attempts to RDP services.

Linux Log Monitoring

Linux systems centralize authentication and security events to standard system log files:

- /var/log/secure: Authentication events including SSH login attempts, sudo usage, and privilege escalation activities.
- /var/log/audit/audit.log: Auditd-generated events for file system integrity monitoring and privileged command execution.
- Brute-force detection: Automated analysis identifies excessive failed authentication attempts from individual source IPs.
- IDS/IPS alerts: Network-based detection systems generate alerts for suspicious traffic patterns and known attack signatures.

Port and Service Monitoring

Network service availability is monitored through port-level health checks. Critical services including RDP (3389), SSH (22), HTTP (80, 5000), LDAP (389), and LDAPS (636) are continuously monitored for connectivity and responsiveness. Service degradation or unavailability triggers immediate alerting to enable rapid incident response.

Alerting Framework

Alert mechanisms have been configured to notify administrators of security-relevant events. Alert conditions include:

- Brute-force detection thresholds exceeded on any authentication service.
- Privilege escalation events detected on Linux systems via sudo logging.
- Service availability degradation or complete service failure.
- IDS/IPS signature matches indicating exploitation attempts or malicious traffic patterns.
- Anomalous process execution detected by Exe Radar Pro on Windows systems.

Certificate and Authentication Controls

Authentication Architecture

Centralized authentication is provided through the Active Directory domain controller. All infrastructure servers are domain-joined to ad.team10.isucdc.com, enabling single sign-on capabilities and centralized user account management. LDAP and LDAPS services provide authentication services for both Windows and Linux systems, as well as web application login functionality.

Domain Integration

All scenario servers maintain active domain membership per competition requirements. Domain membership ensures:

- Centralized user account provisioning and credential management.
- Group Policy Object enforcement for consistent security configuration.
- Kerberos authentication for secure inter-service communication.
- Certificate services integration for cryptographic operations.
- Unified audit logging across domain-joined resources.

Certificate Services Implementation

The domain controller operates as the enterprise Certificate Authority (CA) for the CDC infrastructure. Certificate services support the following functions:

- Ticket signing certificates: Issued to the ticketing server for cryptographic signing operations.
- Certificate enrollment: Automated enrollment available to authorized service accounts via certutil interface.
- Certificate validation: Applications validate certificate chain integrity against the enterprise CA root certificate.
- Certificate revocation: Infrastructure supports certificate revocation checking for compromised certificates.

LDAP/LDAPS Configuration

Directory services are exposed on both standard LDAP (TCP/389) and encrypted LDAPS (TCP/636) ports. LDAPS provides transport-layer encryption for credential transmission, protecting authentication operations from network eavesdropping. All web applications have been configured to use LDAP for user authentication, eliminating local credential databases and ensuring consistent credential policies.

Ticket Cryptographic Operations

The ticketing system implements asymmetric cryptography for ticket integrity protection. Tickets are signed using private keys associated with certificates issued by the enterprise CA. The SIGNING_CERT_THUMBPRINT environment variable ensures that only authorized certificates are used for signing operations. Ticket validation verifies digital signatures using the corresponding public keys, preventing ticket forgery and ensuring ticket authenticity.

Overall Defensive Strategy

Defense-in-Depth Approach

The defensive posture implements multiple layers of security controls across network, host, and application tiers. This approach ensures that compromise of a single security control does not result in complete system compromise. Redundant controls provide defense-in-depth protection against sophisticated adversaries.

Attack Surface Reduction

Systematic reduction of attack surface has been prioritized across all infrastructure components:

- Unnecessary services disabled on all platforms to eliminate unused network listeners.
- Default web pages and debugging interfaces removed from production deployments.
- User account inventory reviewed with non-essential accounts removed or disabled.
- File permissions restricted to prevent unauthorized access to sensitive configuration data.
- Firewall rules configured with default-deny policies, permitting only essential traffic flows.

Privilege Management

Principle of least privilege has been enforced through systematic privilege review. Administrator accounts maintain elevated privileges necessary for system management, while service accounts operate with minimal permissions scoped to application requirements. Root SSH login is disabled on Linux systems to prevent direct privileged remote access. Sudo usage is logged and monitored for unauthorized privilege escalation attempts.

Service Availability Protection

Ensuring service availability is critical for competition scoring. Service persistence mechanisms have been implemented through systemd units on Linux platforms and scheduled tasks on Windows systems. Application configuration has been validated to ensure proper startup after system reboots. Dependencies between services have been mapped to enable proper recovery sequencing in the event of service disruption.

Incident Detection and Response

Comprehensive monitoring provides early warning of potential security incidents. Automated alerting reduces response time for critical events. Log aggregation enables correlation of events across multiple systems to identify coordinated attack patterns. Incident response procedures prioritize service restoration while preserving forensic evidence for post-incident analysis.

Configuration Management

Security configuration baselines have been established for both Windows and Linux platforms. Configuration consistency is maintained through documented hardening procedures. Critical configuration files are protected through restrictive permissions and integrity monitoring. Changes to security-relevant configuration are logged for audit purposes.

Conclusion

The CDC transportation infrastructure has been hardened through systematic application of security controls across all infrastructure tiers. Defense-in-depth protections provide layered security against adversary actions. Comprehensive monitoring enables early detection of security incidents. The infrastructure is continuously monitored and maintained to ensure resilience under adversarial conditions. Ongoing security operations focus on log analysis, configuration integrity, and sustained service availability throughout the competition lifecycle.